

Gün 12 — Dosya Yükleme Endpoint'i

Hedef

Kullanıcının şüpheli bir görsel dosyayı yükleyebileceği `POST /api/v1/analyze` endpoint'ini yazmak: dosyayı geçici bir dizine kaydeden, yalnızca PNG/JPEG'e izin veren ve boyut sınırı uygulayan bir giriş noktası.

Yaklaşım

1. `UploadFile` ile endpoint tanımı

`backend/app/main.py` içine `file: UploadFile = File(...)` parametrelili `POST /api/v1/analyze` eklendi. Başarılı yükleme `201 Created` ile `UploadAck` şeması dönüyor (Gün 14'te `AnalyzeResponse` in yerini alacağı yer tutucu — bkz. Notlar).

2. MIME type doğrulaması: yalnızca header'a güvenmemek

Plan yalnızca "MIME type doğrulaması" istiyordu, ama bu projenin tehdit modeli tam olarak "dosya uzantısı/Content-Type'ın gerçek içerikle uyuşmaması" (Gün 1-2'de incelenen magic bytes) olduğundan, `file.content_type` header'ına (client tarafından kolayca sahteleştirilebilir) tek başına güvenilmedi. Doğrulama iki aşamalı: 1. `Content-Type` başlığı `image/png` veya `image/jpeg` beyaz listesinde mi? 2. Dosyanın ilk baytları (`docs/format-notlari.md` 'deki PNG imzası `89 50 4E 47 0D 0A 1A 0A / JPEG SOI FF D8`) beyan edilen türle eşleşiyor mu? İkisi de tutmazsa `400 Bad Request` + açıklayıcı mesaj dönüyor. Bu, Gün 2'de çıkarılan format bilgisinin ilk kez API tarafında güvenlik kontrolü olarak kullanılması.

3. Boyut sınırı

Dosya içeriği okunduktan sonra `len(content)` bir üst sınırla (25 MB) karşılaştırılıyor; aşılsa `413 Content Too Large` dönüyor (eski `HTTP_413_REQUEST_ENTITY_TOO_LARGE` sabiti FastAPI 0.141'de deprecated olduğu için güncel `HTTP_413_CONTENT_TOO_LARGE` kullanıldı).

4. Geçici kayıt

Dosya, orijinal dosya adı yerine `uuid4().hex + uzantı` ile `backend/tmp/` altına yazılıyor (path traversal / dosya adı çakışması riskini ortadan kaldırmak için). `backend/tmp/` zaten Gün 11'den

beri `.gitignore` 'da.

5. UploadAck modeli

`backend/app/models.py` 'ye eklendi: `filename` , `content_type` , `size_bytes` , `saved_as` . Gün 13'te pipeline bağlanınca bu endpoint `AnalyzeResponse` dönecek; `UploadAck` yalnızca Gün 12'nin kabul kriterini (başarılı/başarısız yükleme) doğrulamak için geçici bir sözleşme.

Dosyalar

```
backend/app/main.py    # POST /api/v1/analyze eklendi
backend/app/models.py  # UploadAck modeli eklendi
```

Test Sonuçları

`uvicorn app.main:app` başlatılıp `curl -F` ile manuel test edildi:

Senaryo	Content-Type (beyan)	Beklenen	Sonuç
<code>samples/sample.png</code>	<code>image/png</code>	201 + UploadAck	✓ 201 , dosya <code>backend/tmp/<uuid>.png</code> olarak kaydedildi
<code>samples/sample.jpg</code>	<code>image/jpeg</code>	201 + UploadAck	✓ 201 , dosya <code>backend/tmp/<uuid>.jpg</code> olarak kaydedildi
<code>.txt</code> dosyası, gerçek <code>text/plain</code>	<code>text/plain</code>	400	✓ 400 "Desteklenmeyen dosya türü: 'text/plain'..."
<code>.txt</code> dosyası, Content-Type sahte <code>image/png</code>	<code>image/png</code>	400 (magic bytes uyumsuzluğu)	✓ 400 "...magic bytes doğrulaması başarısız."
26 MB sahte PNG (geçerli imza + rastgele veri)	<code>image/png</code>	413	✓ 413 "Dosya çok büyük: 27262984 bayt..."

Senaryo	Content-Type (beyan)	Beklenen	Sonuç
GET /docs	—	200, yeni endpoint listelenmeli	✓ 200, openapi.json 'da /api/v1/analyze mevcut

```
$ curl -F "file=@samples/sample.png;type=image/png"
http://127.0.0.1:8000/api/v1/analyze
{"filename":"sample.png","content_type":"image/png","size_bytes":217,"saved_as":"251cdc40142f48c7b6898e00bf1107d0.png"}
```

Kabul Kriterleri — Durum

- [x] Swagger UI (/docs) üzerinden bir görsel dosyası yüklenip başarıyla kabul ediliyor
- [x] Desteklenmeyen bir dosya türü (.txt) yüklendiğinde uygun hata dönüyor (hem gerçek hem sahte Content-Type ile test edildi)

Notlar / Riskler

- Şu anda tüm dosya içeriği belleğe okunup (await file.read()) sonra boyut kontrolü yapılıyor; çok büyük yüklemelerde bu bellek israfı yaratabilir (üretim ortamı için chunk bazlı okuma + erken kesme daha doğru olurdu). Bu projenin eğitim/demo kapsamında kabul edilebilir bulundu, ancak Gün 15'teki hata yönetimi gününde tekrar gözden geçirilebilir.
- UploadAck geçici bir modeldir; Gün 14'te AnalyzeResponse in tüm alanları (threat_score, extracted_video_url, analysis_summary) devreye girince bu endpoint'in dönüş tipi değişecek.